

НОРМАТИВНО-АНАЛИТИЧЕСКАЯ МОДЕЛЬ И МЕТОДИКА ОЦЕНКИ ШТАТНОЙ ЧИСЛЕННОСТИ ПОДРАЗДЕЛЕНИЙ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

В.В. Грызунов, Ю.А. Лысенко, А.В. Шестаков

Несмотря на законодательное требование к корпоративным структурам создавать подразделения информационной безопасности научно обоснованная методология определения их штатной численности отсутствует. Разработана нормативно-аналитическая модель, формально связывающая требуемую численность персонала с количественными параметрами защищаемой корпоративной IT-инфраструктуры и трудоемкостью работ согласно утвержденным федеральным нормам. Выявлена диагностическая функция модели: прямое применение норматива на консультирование пользователей привело к аномально высокому результату, что продемонстрировало способность модели выявлять процессы с необоснованной трудоемкостью, требующие оптимизации или автоматизации. Определена область применения модели, разграничивающая повседневную (нормированную) деятельность от экстремальной (реагирование на инциденты) и научно-исследовательской, для которых требуются иные подходы к нормированию. Перспективными направлениями развития модели являются ее интеграция с методами расчета дежурных смен и введение коэффициентов, учитывающих уровень квалификации персонала, либо дополнительных ролей согласно квалификационной решётке.

Ключевые слова: информационная безопасность, ресурсы информационной безопасности, нормативно-аналитическая модель.

Введение

Стремительная цифровизация всех сфер деятельности в условиях роста интенсивности и сложности киберугроз, направленных на критическую информационную инфраструктуру Российской Федерации, порождают проблему обеспечения информационной безопасности (ИБ) корпоративных информационных инфраструктур (КИИ). Указ Президента РФ от 1 мая 2022 г. № 250 и Приказ ФСТЭК России от 11.02.2013 г. № 17 (пункт 9) прямо указывают на необходимость создания специализированных ИБ-подразделений по обеспечению КИИ и возлагают на руководителей персональную ответственность за ее состояние. Сложившаяся практика формирования штатов по остаточному принципу или на основе экспертных оценок приводит к хроническому кадровому дефициту, перегрузке ИБ-специалистов и, как следствие, к повышению рисков реализации угроз безопасности информации. Реализация требований сталкивается с серьезной методологической проблемой: отсутствием

научно обоснованных подходов к определению необходимой штатной численности ИБ-подразделений.

Анализ проблемной области

В современных исследованиях все больше внимания уделяется человеческому фактору в обеспечении информационной безопасности. Например, в статье [1] авторы показывают, что ключевым элементом является культура ИБ внутри подразделений, и одним из важнейших компонентов этой культуры – наличие у сотрудников достаточных профессиональных навыков (IS skill). Авторы констатируют, что зачастую задачи по защите информации поручаются персоналу, не обладающему необходимой квалификацией, что ведет к снижению общего уровня защищенности КИИ.

Однако, признавая важность «мягких» факторов, таких как культура и мотивация, существующие исследования оставляют без ответа ключевой управленческий вопрос: какое количество квалифицированных специалистов необходимо для выполнения всего комплекса задач по ИБ?

В систематическом обзоре 58 научных статей за 10 лет [2] убедительно

доказывается, что ключевыми факторами формирования культуры ИБ являются поддержка руководства, наличие четких политик, а также постоянное обучение и повышение осведомленности персонала. Вместе с тем практическая реализация мероприятий требует значительных трудовых ресурсов (ИБ-специалистов). Вопрос количественной оценки трудозатрат и определения необходимой штатной численности для их выполнения остается за рамками значительной части исследований в данной области.

Автор работы [3] справедливо отмечает, что традиционные методы нормирования для оценки интеллектуального и аналитического труда сотрудников служб безопасности неэффективны, и указывает на необходимость разработки новых подходов. Автор доказывает актуальность проблемы, однако исследование носит постановочный характер, конкретный инструмент для решения заявленной задачи не указан.

Исследование [4] фокусируется на функциях центров мониторинга и реагирования на инциденты (SOC). В исследовании предложена модель, основанная на оценке производительности аналитиков по обработке потока событий безопасности. Такой инцидентно-ориентированный подход, безусловно, актуален для организаций с высоким уровнем зрелости ИБ, создающих полноценные SOC. Однако он не охватывает весь спектр задач, возлагаемых на ИБ-подразделения в большинстве корпоративных структур. Вне рамок подобных моделей остается значительный объем плановых, превентивных и поддерживающих работ: администрирование средств защиты информации (СЗИ) и программного обеспечения (ПО) на конечных точках, управление криптосредствами, техническая поддержка пользователей, ведение эксплуатационной документации и др.

Существующие подходы к нормированию труда в смежных областях безопасности также подтверждают перспективность использования математических моделей. Так, в работе [5] приведена методика расчета численности

дежурных смен пунктов управления комплексной безопасностью. Авторы используют модель, основанную на нормах времени и нормах выработки, для определения необходимого числа операторов, выполняющих задачи мониторинга. Представленная методика ориентирована на специфику непрерывного дежурства и обработку входящих информационных потоков, что не в полной мере отражает весь спектр задач ИБ-подразделений. Деятельность ИБ-специалистов включает в себя значительный объем плановых, регламентных и проектных работ (администрирование инфраструктуры, установка и обновление ПО, консультирование пользователей), трудоемкость которых зависит не столько от интенсивности потока инцидентов, сколько от масштаба и сложности защищаемой информационной системы.

За рубежом также предпринимаются попытки создания моделей для расчета численности ИТ-персонала.

Особого внимания заслуживает работа иранских исследователей [6], которые предложили предиктивную модель для больниц, основанную на методе Дельфи и многокритериальной оценке (MCDM). Сильной стороной предложенного подхода является формализованная процедура выявления и взвешивания показателей факторов, влияющих на рабочую нагрузку. К сожалению, используемая модель опирается на субъективные экспертные оценки как при определении весов показателей факторов, так и при калибровке итоговой расчетной формулы, что снижает объективность и воспроизводимость результатов.

Проблемы управления информационной безопасностью на стратегическом уровне подробно рассмотрены в работе [7]. Авторы предложили интегрированную концептуальную модель, которая систематизирует подход к ИБ через четыре ключевых аспекта: среду, цели, требования и оценку. Модель является ценным инструментом для руководителей при формировании общей стратегии. Однако, будучи высокоуровневой и качественной по своей природе, модель не затрагивает

операционные вопросы реализации этой стратегии и не дает инструментов для оценки необходимых для этого ресурсов. Образуется методологический разрыв между стратегическим пониманием «что делать» и операционным расчетом «какими силами это делать». Данный разрыв не позволяет полноценно реализовать обратную связь в иерархической информационной системе [8, 9], связывающую уровень персонала с обеспечивающим уровнем, уровнями аппаратного и программного обеспечения информационной системы (ИС).

Цель настоящего исследования – разработать математическую модель и методику расчета штатной численности ИБ-специалистов для операционного кадрового планирования, являющиеся связью между всеми уровнями ИС (КИИ).

Формальная постановка задачи

Дано: пусть защищаемая корпоративная информационная инфраструктура описывается вектором типов объектов

$$\Pi = \langle \pi_1, \pi_2, \dots, \pi_m \rangle,$$

где m – общее число типов объектов,

π_j – конкретный тип объекта, например, АРМ, сервер, пользователь, аттестованная ИС, СЗИ) и вектором количества объектов

$$P = \langle p_1, p_2, \dots, p_m \rangle,$$

p_j – числовое значение (количество) объектов π_j типа.

Пусть S множество ролей (должностей)

$$S = \{s_1, s_2, \dots, s_k\},$$

где k – число ролей в подразделении ИБ (например, s_{tech} – техник, s_{eng} – инженер, s_{head} – руководитель), которые определены в соответствии с профессиональными стандартами.

Для каждой $s_i \in S$ роли определено множество регламентированных трудовых F_i функций и множество всех уникальных функций в подразделении:

$$F_{total} = F_1 \cup F_2 \cup \dots \cup F_k.$$

Для каждой s_i роли множество функций F_i разделяется на два непересекающихся подмножества:

F_{ivar} – трудоемкость которых масштабируется в зависимости от количества объектов;

F_{ifix} – с фиксированной годовой трудоемкостью, не зависящей от масштаба инфраструктуры (например, планирование, отчетность, разработка политик).

Нормативная база и параметры определены. Матрица релевантности R : бинарная матрица размерностью $|F_{total}| \times m$, где элемент $r_{ij} = 1$, если функция $f \in F_{total}$ применима к объектам π_j типа, и $r_{ij} = 0$ в противном случае. Пусть нормативы времени заданы следующим образом:

для каждой функции $f \in F_{var}$ (где $F_{var} = \cup F_{ivar}$) и каждого типа объекта $\pi_j \in \Pi$ определен норматив $T_{norm}(f, \pi_j)$ – трудозатраты в человеко-часах на выполнение операции f над одной единицей π_j объекта;

для каждой функции $f \in F_{fix}$ (где $F_{fix} = \cup F_{ifix}$) определена фиксированная годовая трудоемкость $T_{fix}(f)$ в человеко-часах.

Пусть задан эффективный годовой фонд рабочего времени. Вектор $T_{eff\ vec}$ эффективных фондов рабочего времени размерностью k (по числу ролей):

$$T_{eff\ vec} = \langle T_{eff}(s_1), T_{eff}(s_2), \dots, T_{eff}(s_k) \rangle,$$

где $T_{eff}(s_i)$ – скалярная величина, представляющая собой эффективный годовой фонд рабочего времени для одного сотрудника, занимающего s_i роль ($s_i \in S$). Значение рассчитывается индивидуально для каждой роли с учетом специфики отпусков, служебной подготовки и прочих непроизводственных активностей, характерных для данной должности.

Требуется: разработать нормативно-аналитическую модель для расчета штатной численности N_{unit} , которая удовлетворяет ряду условий.

Во-первых, декомпозиция по ролям: модель должна позволять определять требуемую штатную численность $N_{\text{req}}(s_i)$ для каждой $s_i \in S$ роли.

Во-вторых, агрегация: общая штатная численность $N_{\text{total unit}}$ должна определяться как сумма численностей по всем S ролям.

В-третьих, полнота: модель должна учитывать как масштабируемые (переменные), так и не масштабируемые (фиксированные) трудозатраты.

В-четвертых, целочисленность: итоговая численность по каждой $s_i \in S$ роли должна быть целым числом, полученным с округлением в большую сторону для гарантированного выполнения всего объема работ.

Задача: определить на основе входных данных и разработанной модели:

а) годовую трудоемкость $W(s_i)$ для каждой $s_i \in S$ роли:

$$W(s_i) = W_{\text{var}}(s_i) + W_{\text{fix}}(s_i), \quad (1)$$

где:

$$\sum_{f \in F_{\text{var}}} \sum_{j=1 \dots m} r(f, \pi_j) p_j T_{\text{norm}}(f, \pi_j), \quad (2)$$

$$W_{\text{fix}}(s_i) = \sum_{f \in F_{\text{fix}}} T_{\text{fix}}(f), \quad (3)$$

б) требуемую $N_{\text{req}}(s_i)$ штатную численность для каждой роли $s_i \in S$.

$$N_{\text{req}}(s_i) = \lceil W(s_i) / T_{\text{eff}}(s_i) \rceil, \quad (4)$$

где символы $\lceil x \rceil$ – обозначение для функции «потолок» (ceiling function), которая округляет число до целого в большую сторону, так как штатная единица является неделимой;

в) общую $N_{\text{total unit}}$ штатную численность подразделения:

$$N_{\text{total unit}} = \sum_{i=1 \dots k} N_{\text{req}}(s_i). \quad (5)$$

Примечание: нормативно-аналитическая модель должна обладать рядом ключевых свойств, отвечающих

требованиям к современным инструментам кадрового планирования:

объективности: минимизирует влияние субъективных экспертных оценок, основывая расчет на измеряемых параметрах (Р) инфраструктуры и утвержденной нормативной базе (T_{norm} , T_{fix});

воспроизводимости: является полностью детерминированной. При одинаковом наборе входных данных результат расчета будет идентичным, что исключает разночтения, либо обновлять нормативы времени без изменения самой логики расчета путем или обновления нормативов времени без изменения самой логики расчета, изменения входного вектора Р количества объектов, вектора П типов объектов, и S (F_{total}) множеств;

прозрачность: пошаговый алгоритм и однозначные математические формулы делают логику расчета понятной и доступной для проверки и аудита.

Методика расчёта

Расчёт выполняется посредством последовательного выполнения шагов.

Шаг 1. Инициализация входных данных

Определяются и собираются все необходимые входные параметры, формализованные в постановке задачи:

вектор П типов объектов и вектор Р их количества, характеризующие масштаб защищаемой КИИ;

множество S ролей, формирующих структуру ИБ-подразделения;

множества F_{ivar} , F_{ifix} трудовых функций для каждой s_i роли, с разделением на масштабируемые и не масштабируемые.

Нормативная база:

матрица релевантности R, связывающая функции и объекты;

нормативы времени $T_{\text{norm}}(f, \pi_j)$ для масштабируемых функций;

годовая трудоемкость $T_{\text{fix}}(f)$ для не масштабируемых функций.

Вектор эффективных фондов рабочего времени $T_{\text{eff vec}} = \langle T_{\text{eff}}(s_1), \dots, T_{\text{eff}}(s_k) \rangle$, где каждый компонент соответствует определенной s_i роли.

Шаг 2. Расчет $W(s_i)$ суммарной годовой трудоемкости для каждой s_i роли

Общая годовая трудоемкость $W(s_i)$, согласно выражению (1) для каждой $s_i \in S$ роли, рассчитывается как сумма переменной и фиксированной компонент.

2.1. Расчет $W_{\text{var}}(s_i)$ переменной (масштабируемой) трудоемкости

Компонента отражает объем работ, напрямую зависящий от размера и сложности инфраструктуры.

Расчет $W_{\text{var}}(s_i)$ осуществляется путем суммирования произведений количества объектов на соответствующие нормативы времени по всем релевантным функциям и объектам согласно выражению (2).

2.2. Расчет $W_{\text{fix}}(s_i)$ фиксированной трудоемкости

Компонента включает задачи с постоянными годовыми трудозатратами, такие как разработка регламентов, планирование, подготовка периодической отчетности и другие аналитические или управленческие функции и рассчитывается согласно выражению (3).

Шаг 3. Расчет требуемой штатной численности для каждой s_i роли

Расчетная численность для каждой s_i роли определяется согласно выражению (4) как отношение ее суммарной $W(s_i)$ годовой трудоемкости к эффективному фонду рабочего времени $T_{\text{eff}}(s_i)$, предусмотренному для данной s_i роли.

Шаг 4. Расчет $N_{\text{total unit}}$ общей штатной численности подразделения

Итоговая штатная численность ИБ-подразделения $N_{\text{total unit}}$ определяется как сумма требуемых штатных единиц по всем s_i ролям согласно выражению (5).

Границы применения модели

Корректная интерпретация результатов и эффективное практическое применение подразумевают следующее понимание концептуальных основ и границ применимости модели.

1. Фокус на повседневной (регламентной) деятельности. Деятельность по обеспечению ИБ условно разделяется на три типа:

повседневная (регламентная) деятельность: выполнение плановых и регулярных задач, таких как установка и обновление СЗИ, администрирование

систем, управление доступом, техническая поддержка, ведение документации;

экстремальная деятельность (реагирование): отражение кибератак в режиме реального времени, локализация инцидентов и ликвидация их последствий;

научно-исследовательская и проактивная деятельность: анализ новых угроз, исследование уязвимостей, проактивный поиск угроз (Threat Hunting), разработка и тестирование перспективных методов защиты.

Разработанная модель предназначена для оценки трудозатрат исключительно на повседневную (регламентную) деятельность. Модель позволяет рассчитывать численность для поддержания «постоянной боевой готовности» (по аналогии с силовыми ведомствами), но не для ведения активных «боевых действий» в условиях высших степеней готовности, где должны применяться иные нормативы и ресурсы. Задачи экстремального реагирования в корпоративной структуре решает специализированное подразделение. Научно-исследовательская и проактивная работа централизованно поддерживается НКЦКИ, а также силами корпоративных вузов и научно-исследовательских организаций (при наличии). Модель расширяет существующую систему обеспечения ИБ, предоставляя инструмент для нормирования самого массового и рутинного компонента корпоративной ИС.

2. Принцип усреднения и работа с нормативами. Общий объем работ по обеспечению ИБ декомпозируется на дискретные трудовые функции, закрепленные за конкретными должностными ролями в соответствии с профессиональными стандартами. Если работа не может быть декомпозирована, для оценки её трудоёмкости необходим иной подход, либо работа должна учитываться как отдельная F_i функция в модели.

Модель оперирует усредненными показателями трудоемкости, что является ее осознанным методологическим выбором. Действительно, на практике одна и та же задача, например, «установка СЗИ», может занимать как три минуты при

благоприятных условиях, так и трое суток при возникновении нештатных ситуаций.

Цель модели – не хронометрировать каждую отдельную операцию, а рассчитать совокупные трудозатраты на продолжительных временных интервалах (год) и для значительного количества объектов.

Важно подчеркнуть, что используемые усредненные значения не являются экспертной оценкой авторов. Они основаны на официально утвержденных документах – «Сборнике типовых норм времени...», разработанном ФГБУ «НИИ труда и социального страхования» Минтруда России. Таким образом, модель переносит вопрос о корректности конкретного норматива с уровня подразделения на уровень федерального регулятора, что является ее сильной стороной при обосновании штатной численности. Любая система имеет предел производительности, и данная модель позволяет оценить среднюю нагрузку, для обработки которой должна быть рассчитана емкость ИБ-подразделения корпоративной ИС.

3. Квалификация персонала как управленческий ресурс. Модель намеренно не делает различий между специалистами разной квалификации, оперируя понятием «усредненной штатной единицы». Это не недостаток, а отражение ее назначения как инструмента кадрового планирования, а не операционного управления. Модель отвечает на вопрос «сколько человеко-часов требуется для выполнения всего объема регламентных работ?». Задача руководителя – эффективно распределить этот рассчитанный объем работ между сотрудниками с учетом их реальной квалификации и производительности. Более того, такой подход формирует основу для прозрачной мотивационной системы: сотрудник, обладающий высокой квалификацией, способен выполнить свой нормированный объем задач быстрее, высвобождая время для более сложных и интересных проектов (например, участия в проактивной деятельности), профессионального развития или поддержания баланса между работой и личной жизнью.

4. Расчет численности для экстремальных режимов – отдельная задача. Определение необходимого количества сотрудников для эффективного реагирования на кибератаки (экстремальная деятельность) требует принципиально иного подхода, выходящего за рамки данной работы. Такой расчет должен базироваться на риск-ориентированной модели, включающей:

формирование актуальной модели нарушителя и сценариев кибератак;

оценку потенциального ущерба от реализации рисков;

анализ стоимости владения командой реагирования (cost of controls) в сравнении с возможными потерями.

На основе такого комплексного анализа можно обоснованно определять состав и численность дежурных смен SOC или групп реагирования на инциденты (CERT). Представленная модель служит отправной точкой для определения базового штата, который необходимо поддерживать в постоянной деятельности.

5. Линейность модели и допущение о независимости задач. Важной методологической особенностью, определяющей границы применимости модели, является ее строгая линейность. Суммарная годовая трудоемкость $W(s_i)$ рассчитывается согласно выражениям (1) и (2) как линейная комбинация количественных параметров p_j инфраструктуры. Это означает, что модель базируется на двух ключевых допущениях:

во-первых, отсутствие эффекта «экономии на масштабе» или роста «издержек с ростом масштаба». В модели принято, что трудозатраты на обслуживание $2N$ объектов ровно в два раза больше, чем на обслуживание N объектов. На практике, при использовании современных средств автоматизации (например, систем централизованного развертывания ПО или управления конфигурациями), трудоемкость на единицу объекта обычно снижается по мере роста их числа, но может и увеличиваться [10]. Данный аспект требует отдельного изучения;

во-вторых, независимость и аддитивность трудозатрат. Модель не

учитывает сложность, порождаемую взаимосвязями между элементами системы. Предполагается, что задачи по администрированию разных объектов независимы, и общая трудоемкость является их простой суммой. В реальности, с ростом числа серверов и сетевых устройств сложность управления их взаимодействием (настройка правил доступа, диагностика сетевых проблем, управление зависимостями) может расти нелинейно.

Подход является осознанным методологическим упрощением, продиктованным основной целью – создать объективный и воспроизводимый инструмент на основе утвержденных нормативов, которые сами по себе являются линейными (т.е. даны в формате «человеко-часов на единицу объекта»). Таким образом, модель корректно оценивает базовую трудоемкость выполнения регламентных, повторяющихся операций в их «атомарном» виде.

Учет нелинейных факторов, связанных со сложностью архитектуры системы или, наоборот, с эффективностью ее автоматизации, выходит за рамки данной модели и остается в зоне ответственности руководителя. Результаты моделирования могут служить отправной точкой для обоснования проектов по внедрению средств автоматизации (чтобы снизить базовую трудоемкость) или для введения дополнительных «коэффициентов сложности» при планировании штата для особо крупных и гетерогенных инфраструктур.

Контрольный пример

Расчет штатной численности структурного ИБ-подразделения проведем для одного из сегментов корпоративной ИС в соответствии с методикой, описанной выше.

Шаг 1. Инициализация входных данных

На основе требований руководящих документов и практических данных о моделируемой ИС формализуем параметры.

1.1. Вектор P типов объектов и вектор R их количества

Количественные параметры инфраструктуры (вектор P) примем для одного из сегмента корпоративной ИС.

Параметры, отсутствующие в явном виде, введем как обоснованные допущения:

p_{arm} : автоматизированные рабочие места (АРМ) – не менее 2500 ед.;

$p_{arm rem}$: АРМ, требующие первоначальной установки или переустановки ПО (согласно «Сборнику....» Минтруда оценка: 10% от общего числа в год) – не менее 250 ед.;

$p_{servers core}$: ключевые серверы – 7 ед. (первого типа – 2 ед.; второго типа – 2 ед.; третьего типа – 2 ед.; четвертого типа – 1 ед.);

p_{mse} : межсетевые экраны уровня ядра сети – 1 ед. (пятого типа – 1);

$p_{net devices}$: сетевые устройства (маршрутизаторы, коммутаторы) – не менее 400 ед.;

p_{users} : пользователи (операторы систем) – не менее 1900 чел.;

$p_{crypto total lic}$: общее число криптолицензий (первого типа, второго типа, третьего типа) – не менее 1900 ед.;

$p_{db backup}$: базы данных, подлежащие резервированию (допущение: по числу серверов + FTP) – не более 10 ед.;

$p_{arm incident}$: АРМ с инцидентами, требующими восстановления ПО (статистическая оценка, данные можно получить, например, из Service Desk или журнала учета инцидентов) – не более 1200 ед.

1.2. Ролевая структура (S) и распределение функций (F_i)

Руководящим документом [11] предусмотрены следующие обобщенные трудовые функции, возлагаемые на техников, инженеров и руководителей в ИБ сфере:

обслуживание систем защиты информации в ИС;

обеспечение защиты информации в ИС в процессе их эксплуатации;

внедрение и разработка систем защиты информации ИС;

формирование требований к защите информации в ИС.

В организационной структуре сегмента корпоративной ИС явно просматриваются

три роли: техник, инженер, руководитель. Использование модели в расчётах для других подразделений или организаций вне контрольного примера, где присутствуют дополнительные роли, множество ролей (должностей) S и множество всех уникальных функций в подразделении: F_{total} будут другими.

Примем для контрольного примера три ключевые роли:

S_{tech} : техник по защите информации;
 S_{eng} : инженер по защите информации;
 S_{head} : руководитель ИБ-подразделения.

1.3. Матрица R релевантности, нормативная база (T_{norm} , T_{fix}) и ее практическая корректировка

Нормативы времени примем для контрольного примера из сборника [12].

Для наглядности и полного соответствия формальной постановке задачи, представим совокупность масштабируемых трудовых функций (F_{var}), их применимость к объектам (суть матрицы R релевантности) и соответствующие нормативы времени (T_{norm}) в виде сводной таблицы (табл. 1).

Корректировка норматива: норматив 12,0 чел.-час/пользователя (п. 3.15) для функции $f_{eng\ 11}$ (Консультирование), вероятно, предназначен для первичного обучения. Для расчета текущей поддержки принят скорректированный экспертный норматив $T_{norm\ adj}(f_{eng\ 11}) = 1,0$ чел.-час/год, что дает более адекватную модель.

Примем, что T_{fix} фиксированная трудоемкость:

для инженера:

$$T_{fix}(f_{eng\ doc}) + T_{fix}(f_{eng\ training}) = 160 + 32 = 192 \text{ (чел.-часа/год);}$$

для руководителя (сумма управленческих задач):

$$T_{fix}(f_{head\ total}) = 1140 \text{ чел.-часов/год.}$$

1.4. Эффективный годовой фонд T_{eff} рабочего времени

В общем случае, T_{eff} является вектором, но применительно к корпоративным ИС можно считать, что величина показателя одинакова для всех ролей.

Далее в расчётах T_{eff} используется как скаляр:

$$T_{eff} = 1979 - (304 + 173 + 220 + 100) = 1182,$$

где $T_{год}$ – количество рабочих часов сотрудника в год составляет 1979 [13];

$T_{отпуск}$ – минимальная длительность отпуска сотрудника составляет 304 ч/год;

$T_{пп}$ – профессиональная переподготовка сотрудника составляет 173 ч/год (данные из корпоративных локальных правовых актов о порядке подготовки специалистов и программ профессиональной переподготовки специалистов);

$T_{сп}$ – самостоятельная подготовка сотрудника 220 ч/год;

$T_{фп}$ – минимальное количество часов на занятия по физической подготовке специалистов 100 ч/год (при наличии корпоративных требований).

Шаг 2. Расчет годовой трудоемкости

Расчеты проведены согласно выражениям (1) - (3) и данным из табл. 1.

2.1. Расчет $W(S_{tech})$ для роли «Техник по защите информации» часа (фиксированные затраты отсутствуют)

$$W_{var}(S_{tech}) = (250 * 2,4) + (2500 * 1,8) + (2500 * 0,5) + (435 * 2,4) + (1970 * 1,0) + (1900 * 2,4) = 13\ 924 \text{ (чел.-часа).}$$

2.2. Расчет $W(S_{eng})$ для роли «Инженер по защите информации»

$$W_{var}(S_{eng}) = (7 * 17,0) + (1970 * 0,5) + (1 * 1,5) + (7 * 126,0) + (2500 * 1,8) + (1 * 75,6) + (1900 * 1,0) + (9 * 100,8) + (1200 * 1,6) + (7 * 24,0) + (1900 * 1,0) = 192 \text{ (чел.-часа).}$$

2.3. Расчет $W(S_{head})$ для роли Техники (S_{tech}):
«Руководитель отдела»

$$N_{req}(S_{tech}) = [13924/1182] = [11,78] = 12.$$

$$W(S_{head}) = W_{fix}(S_{head}) = 1140 \text{ чел.-часов}$$

Инженеры (S_{eng}):

Шаг 3. Расчет требуемой штатной численности (ед.) согласно выражению (4):

$$N_{req}(S_{eng}) = [13550/1182] = [11,46] = 12.$$

$$N_{req}(S_i) = [W(S_i)/T_{eff}],$$

Руководитель (S_{head}):

где $T_{eff} = 1182$.

$$N_{req}(S_{head}) = [1140/1182] = [0,96] = 1.$$

Таблица 1

Матрица релевантности и нормативы для масштабируемых функций

Код функции (f)	Наименование трудовой функции	Применимый тип объекта (π_i)	Параметр количества (p_i)	Норматив $T_{norm}(f, \pi_i)$, чел.-час
Техник				
$f_{tech} 1$	Установка ПО на АРМ	АРМ (новые/ремонт)	$P_{arm rem}$	2,4
$f_{tech} 2$	Контроль и поддержка АРМ	АРМ	p_{arm}	1,8
$f_{tech} 3$	Конфигурация АРМ	АРМ	p_{arm}	0,5
$f_{tech} 4$	Монтаж и диагностика сетей	Сетевые устройства	$p_{net devices}$	2,4
$f_{tech} 5$	Установка криптосредств	Крипто-лицензии	$p_{crypto total lic}$	1,0
$f_{tech} 6$	Информирование персонала	Пользователи	p_{users}	2,4
Инженер				
$f_{eng} 1$	Администрирование серверов	Серверы	$p_{servers core}$	17,0
$f_{eng} 2$	Администрирование криптосредств	Крипто-лицензии	$p_{crypto total lic}$	0,5
$f_{eng} 3$	Администрирование МСЭ	МСЭ	p_{mse}	1,5
$f_{eng} 4$	Инструментальный контроль серверов	Серверы	$p_{servers core}$	126,0
$f_{eng} 5$	Инструментальный контроль АРМ	АРМ	p_{arm}	1,8
$f_{eng} 6$	Инструментальный контроль МСЭ	МСЭ	p_{mse}	75,6
$f_{eng} 7$	Управление полномочиями	Пользователи	p_{users}	1,0
$f_{eng} 8$	Резервное копирование БД	Базы данных	$p_{db backup}$	100,8
$f_{eng} 9$	Восстановление ПО после сбоев	АРМ с инцидентами	$p_{arm incident}$	1,6
$f_{eng} 10$	Обеспечение безопасности серверов	Серверы	$p_{servers core}$	24,0
$f_{eng} 11$	Консультирование пользователей	Пользователи	p_{users}	1,0 (скорр.)

Шаг 4. Расчет общей штатной численности согласно выражению (5):

$$N_{total unit} = N_{req}(S_{tech}) + N_{req}(S_{eng}) + N_{req}(S_{head})$$

$$N_{total unit} = 12 + 12 + 1 = 25 \text{ (ед.)}.$$

Обсуждение результатов

Требуемая численность ИБ-подразделения для выполнения

повседневных регламентных задач в сегменте корпоративной ИС составляет 25 чел., в том числе: руководитель – 1 чел.; инженеры по защите информации – 12 чел.; техники по защите информации – 12 чел.

Ключевым моментом, влияющим на результат, является корректировка норматива на консультирование пользователей.

Прямое применение норматива (12,0 час/год) регламентирует объем нагрузки в

22,8 тыс. часов. Это требует привлечения 20 инженеров для решения только этой задачи, и итоговый результат в 43 потребных специалистов – практически нереализуемым и не обоснованным для изменения штатной численности ИБ-подразделения.

Разработанная модель является не просто «калькулятором», но и диагностическим инструментом. Модель позволяет выявлять задачи с аномально высокой или необоснованной трудоемкостью, которые являются главными кандидатами на оптимизацию, автоматизацию (например, через внедрение базы знаний или чат-ботов на базе искусственного интеллекта) или пересмотр действующих и принятых регламентных процедур. Модель дает руководителю объективные данные для принятия обоснованных управленческих решений в области кадровой политики и политики обеспечения информационной безопасности корпоративной информационной инфраструктуры.

Заключение

В настоящей работе решена актуальная научная задача по разработке и апробации нормативно-аналитической модели для объективного расчета штатной численности подразделений информационной безопасности в корпоративных структурах. Модель разработана для устранения методологического разрыва между требованием регуляторов о создании ИБ-подразделений в системах информационной безопасности корпоративных информационных инфраструктур, особенно относящихся к критическим и отсутствием формализованных инструментов для определения их необходимой численности, что на практике приводит к хроническому кадровому дефициту и повышению рисков.

Модель основывается на трех ключевых принципах: декомпозиции трудовых функций в соответствии с профессиональными стандартами, привязки трудозатрат к измеряемым параметрам защищаемой инфраструктуры и использования утвержденной на федеральном уровне нормативной базы. Позволяет перейти от субъективных

экспертных оценок к воспроизводимому и прозрачному аналитическому расчету.

Апробация модели на примере сегмента корпоративной ИС продемонстрировала ее практическую применимость. Расчет показал, что для выполнения всего объема повседневных регламентных задач требуется подразделение в составе 25 человек (1 руководитель, 12 инженеров, 12 техников).

Важнейшим результатом апробации стала демонстрация диагностической функции модели: она позволила выявить задачу с аномально высокой нормативной трудоемкостью («Консультирование пользователей») и обосновать необходимость ее корректировки, что указывает на потенциал модели как инструмента для анализа и оптимизации бизнес-процессов в ИБ-сфере. Главная практическая ценность представленной работы заключается в том, что она предоставляет руководителям корпоративных структур мощный, основанный на доказательствах аргумент для диалога с кадровыми и финансовыми службами. Модель позволяет объективно обосновать потребность в персонале, привязав ее к масштабу IT-инфраструктуры и требованиям официальных нормативных документов.

Модель предназначена для расчета численности персонала, выполняющего повседневную (регламентную) деятельность. Расчет штата для экстремальной (реагирование на инциденты) и научно-исследовательской (проактивный поиск угроз, проектирование СЗИ) деятельности требует иных, как правило, риск-ориентированных подходов и является предметом отдельных исследований.

Направлениями для дальнейшего развития предложенной модели могут стать:

интеграция с моделями расчета численности дежурных смен SOC для создания комплексного подхода к формированию ИБ-подразделений;

введение в модель коэффициентов, которые учитывают уровень квалификации персонала, позволит перейти от расчета «усредненных штатных единиц» к планированию квалификационного состава команды либо введение разных s_i ролей ($s_i \in$

S) согласно квалификационной решётке: техник I категории, II категории и далее с разными $T_{\text{norm}}(f, \pi_i)$ нормативами;

актуализация и расширение используемой нормативной базы для охвата новых технологий, таких как облачные вычисления, контейнеризация и микросервисные архитектуры.

Статья подготовлена в рамках выполнения НИР «Кибермониторинг» по государственному заданию МЧС России (ЕГИСУ НИОКТР №125031703734-4).

Список литературы

1. Dornheim, P., Zarnekow, R. Factors Shaping Information Security Culture in an Internal IT Department // In International Conference on Human-Computer Interaction. 2020. Lecture Notes in Computer Science. Vol. 12427. Pp. 507-521. Springer, Cham. DOI: 10.1007/978-3-030-60152-2_38.
2. Uchendu, B., Nurse, J.R.C., Bada, M., Furnell, S. Developing a Cyber Security Culture: Current Practices and Future Needs // Computers & Security. 2021. Vol.109(2), 102387. DOI: 10.1016/j.cose.2021.102387.
3. Копьев, И.Г. Проблема определения оптимального численного и профессионального состава служб (отделов) безопасности // Креативная экономика. 2021. Том 15. № 4. С. 1557-1568. DOI: 10.183334/се.15.4.111968.
4. Кочин, В.П. Методика создания и структура корпоративного подразделения информационной безопасности / В.П. Кочин, А.В. Шанцов // Цифровая трансформация. 2022. Том 28. № 3. С. 65-72. DOI: 10.35596/2522-9613-2022-28-3-65-72.
5. Кондратьев, А.Ю. Методика определения штатной численности пунктов управления комплексной безопасностью / А.Ю. Кондратьев, И.Е. Новокшенов, А.В. Усов, С.С. Рогожин // Вопросы оборонной техники. Серия 16: Технические средства противодействия терроризму. 2021. № 5-6 (155-156). С. 85-90. EDN WKIRVL.
6. Jangi, M., Babokani, A.S., Rezaei, M., Nasab, S. K., Mirzaei, M., Kazemzadeh, M. Predicting the number of IT staff needed in hospitals of Isfahan University of Medical Sciences based on modeling in 2023: A descriptive-analytical study // Health Science Reports. 2024. Vol.7(7). e2230. DOI: 10.1002/hsr2.2230.
7. Alzahrani, L., Seth, K.P. The Impact of Organizational Practices on the Information Security Management Performance// Information. 2021. 12(10). 398. DOI: 10.3390/info12100398.
8. Грызун, В.В. Модель системы адаптивного управления киберполигоном МЧС России на основе операторного уравнения / В.В. Грызун, А.В. Шестаков // Вопросы кибербезопасности. 2024. № 6(64). С. 140-149. DOI: 10.21681/2311-3456-2024-6-140-149. EDN GSHMNZ.
9. Грызун, В.В. Формирование условия гарантированного достижения цели деятельности информационной системой на базе операторного уравнения // Информатизация и связь. 2022. № 4. С. 67-74. DOI: 10.34219/2078-8320-2022-13-4-67-74. EDN NGLZEW.
10. Максимова, Е.А. Аксиоматика инфраструктурного деструктивизма субъекта критической информационной инфраструктуры // Информатизация и связь. 2022. № 1. С. 68-74. DOI: 10.34219/2078-8320-2022-13-1-68-74. EDN ZMORQB.
11. Приказ Минтруда России «Об утверждении профессионального стандарта «Специалист по защите информации в автоматизированных системах» от 15.09.2016 г. № 522н.
12. Раздел 14 «Работы, выполняемые руководителями, специалистами и служащими» в Сборнике типовых норм времени на техническое и сервисное обслуживание информационных ресурсов в государственных (муниципальных) учреждениях по Реестру сборников норм труда, разработанном Институтом труда и утвержден ФГБУ «Научно-исследовательский институт труда и социального страхования» Минтруда России от 07.03.2014 г. №012.
13. Производственный календарь 2024 года (составлен на основе Постановления Правительства РФ «О переносе выходных дней в 2024 году» от 10.08.2023 № 1314).

Санкт-Петербургский университет ГПС МЧС России
St. Petersburg University of the State Fire Service of the Ministry
of Emergency Situations of Russia

Главное Управление МЧС России Московской области
The Main Directorate of the Russian Ministry of Emergency Situations of the Moscow region

Поступила в редакцию 5.09.25

Информация об авторах

Грызунов Виталий Владимирович – д-р техн. наук, доцент, профессор кафедры прикладной математики и информационных технологий, Санкт-Петербургского университета ГПС МЧС России, e-mail: viv1313r@mail.ru. ORCID <https://orcid.org/0000-0003-4866-217X>.

Лысенко Юрий Александрович – начальник управления информационных технологий и связи Главного Управления МЧС России Московской области. e-mail: lualis@ya.ru. ORCID <https://orcid.org/0009-0003-6384-5828>.

Шестаков Александр Викторович – д-р техн. наук, старший науч. сотрудник, ведущий науч. сотрудник, Санкт-Петербургский университет ГПС МЧС России, e-mail: alexandr.shestakov01@yandex.ru. ORCID <https://orcid.org/0000-0002-8462-6515>.

REGULATORY AND ANALYTICAL MODEL AND TECHNIQUE FOR ASSESSING THE STAFFING OF INFORMATION SECURITY DEPARTMENTS

V.V. Gryzunov, Y.A. Lysenko, A.V. Shestakov

Despite the legislative requirement for corporate structures to create information security units, there is no scientifically substantiated methodology for determining their staffing requirements. A regulatory and analytical model has been developed that formally links the required staffing requirements to the quantitative parameters of the protected corporate IT infrastructure and the complexity of routine work in accordance with approved federal standards. The diagnostic function of the model was identified: the direct application of the user consultation standard resulted in an abnormally high score, demonstrating the model's ability to identify processes with unjustified labor intensity that require optimization or automation. The model's application scope has been defined, distinguishing between everyday (calculation) activities and extreme (incident response) and research activities, which require different approaches to regulation. Promising areas for the model's development include its integration with methods for calculating on-duty shifts and the introduction of coefficients that take into account the level of personnel qualifications or additional roles based on the qualification grid.

Keywords: information security, information security resources, regulatory and analytical model.

Submitted 5.09.25

Information about the authors

Vitaly V. Gryzunov – Dr. Sc. (Technical), Associate Professor, Professor of the Department of Applied Mathematics and Information Technologies at the St. Petersburg University of the State Fire Service of the Ministry of Emergency Situations of Russia. e-mail is viv1313r@mail.ru. ORCID <https://orcid.org/0000-0003-4866-217X>.

Yuri A. Lysenko – Head of the Department of Information Technologies and Communications of the Main Department of the Russian Ministry of Emergency Situations in the Moscow Region. e-mail is lualis@ya.ru. ORCID <https://orcid.org/0009-0003-6384-5828>.

Alexander V. Shestakov – PhD, Senior Researcher, Leading Researcher of St. Petersburg University of the State Fire Service of the Ministry of Emergency Situations of Russia, e-mail: alexandr.shestakov01@yandex.ru. ORCID <https://orcid.org/0000-0002-8462-6515>.